Ad Soyad: _____	**Tarih:** _____
Bölüm 13 – Ünite 4 – *Güvenlik Temelleri – Çalışma Kağıdı*	

Süre

Bu çalışma kağıdını tamamlamak için tahmini süre: **40–45 dakika**.

Konu Hatırlatma

Bu ünitede **tehdit modeli**, **parola hash'leme** (salt + yavaşlatma), **TLS** (gizlilik, bütünlük, kimlik, replay direnci), **girdi doğrulama** (üç geçişli süzgeç), **kimlik doğrulama vs yetkilendirme** ayrımı işlendi. Detaylar için: `sec:13_u4_qcryptographichash`, `sec:13_u4_ssl_tls`, `sec:13_u4_girdi_dogrulama`.

Görev 1: Tehdit Modeli – Saldırgan × Varlık

(8 dakika – 22 puan)

G1: 3 Saldırgan × 3 Varlık Matrisini Doldur

Her hücreye o saldırganın o varlığa karşı yapabileceği *en olası saldırı türünü* ve *savunma katmanını* yazın.

Saldırgan ↓ / Varlık →	**Parola tablosu**	**Ağ trafiği**	**Aktif oturum jetonu**
İçerden (sysadmin, kötü çalışan)			
Dışardan (internetten)			
Aynı ağda dinleyici (kafe Wi-Fi'si)			

İpucu

"Pasif dinleyici", "veritabanı sızdırıcısı", "MitM (ortadaki adam)" kategorilerini düşün. Savunma katmanları: salt+yavaşlatılmış hash, TLS, kısa ömürlü token, role-based authorization.

Görev 2: Ham SHA-256 Yetersiz mi?

(7 dakika – 18 puan)

G2: 3 Saldırı Türünü Kısaca Açıkla

Tuzsuz, tek geçişli SHA-256 ile saklanan parola tablosu üç klasik saldırıya açıktır. Her birini 1-2 cümle ile açıkla ve *savunma*sını söyle.

Saldırı 1 – Sözlük saldırısı (dictionary attack):

Açıklama: _____

_____

Savunma: _____

Saldırı 2 – Gökkuşağı tablosu (rainbow table):

Açıklama: _____

_____

Savunma: _____

Saldırı 3 – Kaba kuvvet hızı (GPU brute force):

Açıklama: _____

_____

Savunma: _____

Soru: Üç savunma birlikte uygulandığında üretilen parola hash'inin biçimi tipik olarak şöyle görünür: `$2y$12$xxxxxxxxxxxxxxxxxxxxxx...`
Bu format hangi algoritmanın çıktısıdır ve 12 sayısı neyi temsil eder?

_____

Görev 3: TLS Handshake – Adımları Sırala

(7 dakika – 18 puan)

G3: TLS 1.2 El Sıkışmasının 6 Adımını Numaralandır

Aşağıdaki kartlar karışık verilmiştir; doğru sırada 1-2-3-4-5-6 olarak numaralayın.

_____ **ChangeCipherSpec / Finished:** İki taraf da "bundan sonra şifreli konuşalım" diyerek el sıkışmayı bitirir.

_____ **Application Data:** Uygulama verisi (OBYS JSON mesajları) simetrik anahtarla şifreli olarak akar.

_____ **Anahtar değişimi (Key Exchange):** ECDHE ile ortak oturum anahtarı türetilir; anahtarın kendisi ağda hiç dolaşmaz.

_____ **Sertifika doğrulama:** İstemci sunucu sertifikasını yerel kök CA listesiyle karşılaştırır.

_____ **ServerHello:** Sunucu seçtiği TLS sürümünü, cipher suite'i, kendi nonce'ını ve sertifikasını gönderir.

_____ **ClientHello:** İstemci desteklediği TLS sürümlerini, cipher suite'leri ve rastgele bir nonce yollar.

Soru a: Hangi adımdan sonra trafik *şifrelenmeye* başlar? _____
Soru b: Sertifika doğrulama *başarısız* olursa ne olur?

_____

Soru c: TLS yalnızca veriyi şifrelemekle kalmaz, başka 3 garanti daha sunar. Bunları listele:

1. _____
2. _____
3. _____

Görev 4: Handler Kodu – Doğrulama Eksiklerini Bul

(10 dakika – 24 puan)

G4: Aşağıdaki Sunucu Handler'ında 4-5 Güvenlik Sorunu Var

Numaralandırarak listele ve her biri için kısa düzeltme yaz.

```
void Sunucu::handleOgrenciEkle(QTcpSocket* s, const QJsonObject& istek) {
    // (a) Sema dogrulama yok; istek["veri"] herhangi bir sey olabilir
    QJsonObject veri = istek["veri"].toObject();
    QString ad     = veri["ad"].toString();
    QString numara = veri["numara"].toString();
    int bolum_id   = veri["bolum_id"].toInt();

    // (b) Yetkilendirme kontrolu yok; her oturum ekleyebilir
    // (c) Boyut/uzunluk kontrolu yok; ad 50 MB olabilir
    // (d) Numarada SQL/komut yapistirma kontrolu yok
```

```
    auto query = QString("INSERT INTO ogrenciler VALUES('%1', '%2', %3)")
                    .arg(ad).arg(numara).arg(bolum_id);
    veritabani_.execute(query);   // (e) Parametre yok!

    // (f) Audit log yok
    cevapGonder(s, {{"durum","ok"}});
}
```

Sorun 1: _____
Düzeltme: _____

Sorun 2: _____
Düzeltme: _____

Sorun 3: _____
Düzeltme: _____

Sorun 4: _____
Düzeltme: _____

Sorun 5: _____
Düzeltme: _____

İpucu

Üç geçişli süzgeci hatırla: (1) şema/protokol, (2) iş mantığı, (3) yetkilendirme. Audit log her durumda eklenir; hatalı denemeler de loglanır.

Görev 5: BONUS – Yetkilendirme Matrisi (3 Rol × 5 Komut) (8 dakika – 18 puan)

G5: Her Hücre İçin İzin (Y) veya Yasak (Y–) Belirle

"Y" = yetkili, "Y–" = yetkisiz, "Y_k" = yalnızca kendi kaydı için yetkili. Her satırı doldurun.

Komut ↓ / Rol →	Öğrenci	Öğretim Üyesi	Sekreter	
`ogrenci_ekle`	_____	_____	_____	
`not_guncelle`	_____	_____	_____	
`kendi_transkriptini_getir`	_____	_____	_____	
`tum_transkriptleri_listele`	_____	_____	_____	
`kendi_parolasini_degistir`	_____	_____	_____	

Soru: Bu matris kodda en temiz nasıl uygulanır? Birkaç tasarım seçeneği önerin:

_____

_____

Tartışma Soruları (sınıf içi açık uçlu)

T1. Kimlik doğrulama (authentication) ile yetkilendirme (authorization) farkı somut bir "Ahmet hangi öğrencinin notunu güncelleyebilir?" örneğiyle nasıl gösterilir?

_____

T2. Self-signed sertifika ile CA imzalı sertifika arasında fark nedir? OBYS dahili (intranet) sürümünde self-signed kabul edilebilir mi?

T3. “Düz parolayı asla logla” kuralı açık. Peki *başarısız login denemesinde* yanlış girilen parola bir hatayla loglanır mı? Etik ve pratik tarafları?

T4. Yetkilendirme matrisini “her komut için fonksiyon başında 1 satır kontrol” yerine “decorator/middleware” olarak çıkarmanın avantajları nelerdir?